Pay29 Solutions

ISO 27001:2022 Gap Analysis Report

Table of Contents

Contents

1 Introduction 3

1.1 Purpose of Gap Assessment 3

2 Executive Summary 4

3 Assessment Methodology 5

4 Detailed Findings 6

5 Gap Analysis Summary 9

6 Recommendation 10

7 Conclusion 11

1 Introduction

Pay29 Solutions is a fintech company providing online payment processing services to its customers. The organization operates a hybrid work model with 85 employees across office and remote environments. Pay29 runs its core infrastructure on AWS, uses Microsoft 365 for collaboration and maintains a PostgreSQL database storing sensitive customer PII and payment transaction records.

1.1 Purpose of Gap Assessment

The purpose of this gap assessment is to evaluate Pay29's current information security posture against the mandatory requirements of ISO 27001:2022 and identify areas where the organization falls short of the standard's expectations.

The assessment aims to:

- Establish a clear baseline of Pay29's current security posture
- Identify gaps across all mandatory ISO 27001:2022 clauses
- Provide prioritized recommendations to address identified gaps
- Lay the foundation for a future ISO 27001:2022 implementation

Scope of the Assessment

Area	Coverage
Standard	ISO 27001:2022
Clauses Assessed	Clauses 4–10 (25 sub-clauses)
Systems in Scope	AWS Cloud Infrastructure, Microsoft 365, PostgreSQL Database, Employee Devices
Data in Scope	Customer PII, Payment Transaction Records, Employee Credentials

2 Executive Summary

The assessment revealed that Pay29 Solutions has no foundational Information Security Management System in place. Operating in a high risk fintech environment, Pay29 currently relies solely on basic perimeter controls with no formal policies, governance or security processes documented. Of the 25 sub-clauses assessed across ISO 27001:2022 Clauses 4–10, 21 were found to be not implemented and 4 were partially implemented.

Observations

- **Basic Perimeter Controls:** A firewall and antivirus solution are in place providing a minimal starting point for security improvement.
- **Existing Vendor Contracts:** Basic agreements exist with third party vendors which can be updated to include security requirements.
- **Willingness to Improve:** The initiation of this gap assessment reflects an organizational intent to address information security seriously.

Major Gaps Identified

- **No ISMS Scope Defined (Clause 4.3):** The scope of ISMS has never been defined for Pay29.
- **No Information Security Policy (Clause 5.2):** Pay29 has no formal policy for information security across the organization.
- **No Defined Security Roles and Responsibilities (Clause 5.3):** No one is assigned the responsibility for security within the organization.
- **No Risk Assessment Process (Clause 6.1.2):** The risks associated with Pay29's IT infrastructure has never been assessed.
- **No Security Awareness Training (Clause 7.3):** Employees of Pay29 have never undergone any security awareness training.
- **No Incident Response Plan (Clause 8.3):** No incident response plan has been developed for Pay29, even though it has encountered a phishing attack three months ago.
- **No Security Monitoring or Internal Audits (Clause 9.1, 9.2):** No program has been developed for monitoring security activities within the organization.
- **No Continual Improvement Process (Clause 10.1):** No mechanism has been developed for improving the ISMS within Pay29.

3 Assessment Methodology

This gap analysis was conducted using ISO 27001:2022 as the primary reference standard. The assessment followed a structured approach to evaluate Pay29's current information security posture against the mandatory requirements of the standard.

Each mandatory clause of ISO 27001:2022 was broken down into its sub-clauses and evaluated individually to provide a granular view of compliance gaps across the organization

Compliance Status

Status	Definition
Implemented	Control or requirement is fully in place and operating effectively
Partially Implemented	Control or requirement exists in some form but is incomplete or informal
Not Implemented	No evidence of the control or requirement being in place

Priority Definitions

Priority	Definition
High	Immediate Action Required
Medium	Action required within 90 days
Low	Action Required within 180 days

4 Detailed Findings

Clause/Sub Clause	Compliance Status	Findings	Recommendations
Clause 4 – Context of the organization			
4.1 Understanding the organization and its context	Not Implemented	Pay29 has never documented its internal or external context	Identify and document internal and external factors
4.2 Understanding needs of interested parties	Not Implemented	No stakeholder analysis has been conducted	Identify key stakeholders and document their security requirements
4.3 Determining the scope of the ISMS	Not Implemented	No ISMS scope has been defined or documented	Define and document the ISMS scope covering all Pay29 systems and data
4.4 Information security management system	Not Implemented	No ISMS has been established or maintained	Establish a formal ISMS aligned to ISO 27001:2022 requirements
Clause 5 - Leadership			
5.1 Leadership and commitment	Not Implemented	Senior management has shown no formal commitment to information security	Senior leadership must officially support the ISMS and show active engagement in its management and effectiveness.
5.2 Policy	Not Implemented	No information security policy exists at Pay29	Develop and publish a formal information security policy approved by top management
5.3 Organizational roles and responsibilities	Not Implemented	No security roles or responsibilities have been formally assigned	Define and communicate security roles and responsibilities across the organization

Clause 6 – Planning			
6.1.1 General risk planning	Partially Implemented	No formal process exists to address risks and opportunities	Establish a formal process to identify and address information security risks
6.1.2 Information security risk assessment	Partially Implemented	No documented risk assessment process or methodology in place	Define and document a repeatable risk assessment methodology aligned to ISO 27001
6.1.3 Information security risk treatment	Not Implemented	No risk treatment plan has been documented or approved	Develop a formal risk treatment plan with assigned owners and target dates
6.2 Information security objectives and planning to achieve them	Not Implemented	No measurable security objectives have been defined	Define measurable security objectives aligned to Pay29's business goals
6.3 Planning of changes	Not Implemented	No process exists to manage changes to the ISMS	Establish a change management process for ISMS updates and modifications
Clause 7 - Support			
7.1 Resources	Not Implemented	No dedicated security resources or budget have been allocated	Allocate appropriate resources and budget for ISMS implementation and maintenance
7.2 Competence	Not Implemented	No security competence requirements defined and no training records maintained	Define security competence requirements and maintain training records for all relevant staff

7.3 Awareness	Not Implemented	Employees have never received security awareness training	Launch a security awareness program covering phishing, data handling and acceptable use
7.4 Communication	Not Implemented	No internal or external security communication process exists	Establish a security communication plan for internal staff and external stakeholders
7.5 Documented information	Not Implemented	No documented information or version-controlled policies exist	Establish document control procedures and maintain all ISMS documentation
Clause 8 – Operation			
8.1 Operational planning and control	Partially Implemented	Basic firewall and antivirus exist but no formal operational controls are documented	Document and implement all operational security controls aligned to the risk treatment plan
8.2 Information security risk assessment	Partially Implemented	No periodic risk assessments are conducted or scheduled	Schedule and conduct risk assessments at planned intervals or after significant changes
8.3 Information security risk treatment	Not Implemented	Risk treatment has never been formally implemented or reviewed	Implement approved risk treatment actions and review their effectiveness regularly
Clause 9 – Performance Evaluation			
9.1 Monitoring, measurement, analysis and evaluation	Not Implemented	No security monitoring or	Define security metrics and establish a monitoring

		measurement program exists	program to track ISMS performance
9.2 Internal audit	Not Implemented	No internal audits of the ISMS have ever been conducted	Plan and conduct regular internal audits to assess ISMS conformance
9.3 Management review	Not Implemented	No management reviews of the ISMS have taken place	Schedule regular management reviews to evaluate ISMS performance and drive improvement
Clause 9 – Improvement			
10.1 Continual improvement	Not Implemented	No continual improvement process exists for the ISMS	Establish a formal process to continually improve the ISMS based on audit findings
10.2 Nonconformity and corrective action	Not Implemented	No process exists to identify nonconformities or take corrective action	Define a nonconformity management process and track corrective actions to closure

5 Gap Analysis Summary

Clause	Total Sub-Clauses	Implemented	Partial	Not Implemented
Clause 4 - Context of the Organization	4	0	0	4
Clause 5 - Leadership	3	0	0	3
Clause 6 -Planning	5	0	2	3
Clause 7 - Support	5	0	0	5
Clause 8 - Operation	3	0	2	1
Clause 9 - Performance Evaluation	3	0	0	3
Clause 10 - Improvement	2	0	0	2
Total	25	0	4	21

6 Recommendations

Immediate Actions

Priority	Clause	Action Item	Action Required	Timeline
High	5.2	Develop Information Security Policy	Create and publish a formal information security policy approved by senior management	0-30 days
High	5.3	Assign Security Roles and Responsibilities	Define and assign security roles and responsibilities across the organization	0-30 days
High	4.3	Define ISMS Scope	Document the ISMS scope covering all Pay29 systems, data and processes	0-30 days
High	8.1	Enforce MFA	Enforce MFA on all Microsoft 365 accounts immediately	0-30 days
High	8.3	Develop Incident Response Plan	Develop a basic incident response plan to address future security incidents	0-30 days

7 Conclusion

The gap analysis has identified significant areas where Pay29 Solutions needs to focus efforts to achieve compliance with ISO 27001:2022. By prioritizing the development of foundational elements such as an Information Security Policy, defined security roles and responsibilities, ISMS scope and a formal risk assessment process, Pay29 can build a strong base for its ISMS.